

INFORMATION SECURITY POLICY

Home SOC Lab — Governance, Risk & Compliance Documentation

Prepared by: Lance Vidaure | Date: May 16, 2026 | Version: 1.0 | Classification: LAB — UNCLASSIFIED

1. PURPOSE & SCOPE

This Information Security Policy establishes the security requirements, acceptable use guidelines, and operational standards for the Home SOC Lab environment. The lab simulates an enterprise security operations environment and is used exclusively for cybersecurity education, skill development, and portfolio demonstration.

This policy applies to all virtual machines, cloud accounts, credentials, and data within the SOC lab environment, including pfSense, Windows Server 2022, Ubuntu/Wazuh, Kali Linux, and AWS free tier resources.

2. ACCEPTABLE USE POLICY

2.1 Permitted Activities

- Deploying and configuring virtual machines for security testing purposes
- Running attack simulations exclusively within the isolated internal network (192.168.10.0/24)
- Analyzing security alerts, logs, and event data generated within the lab
- Developing and testing custom detection rules in Wazuh SIEM
- Documenting findings for portfolio, GitHub, and professional development
- Accessing AWS free tier resources for cloud security monitoring exercises

2.2 Prohibited Activities

- Using lab tools or techniques against any external systems, networks, or individuals
- Storing personally identifiable information (PII) or sensitive data within lab VMs
- Sharing lab credentials, access keys, or passwords in public forums or repositories
- Connecting attacker VMs (Kali) to external networks or the internet
- Violating AWS Terms of Service or free tier usage limits
- Using the lab environment for any commercial or unauthorized purpose

3. ACCESS CONTROL POLICY

3.1 Principle of Least Privilege

All accounts — virtual machine, Active Directory, and cloud — must be provisioned with the minimum permissions required to perform their designated function. Privileged access must be explicitly justified and documented.

AD Domain:	SOC LAB.local — all users created with standard user rights by default
Admin Accounts:	Administrator account used only when elevated access is required
AWS IAM:	soclab-analyst user provisioned with ReadOnlyAccess only
MFA Requirement:	MFA required on all AWS console accounts — enforced via IAM policy
SSH Access:	Key-based authentication preferred; password auth limited to lab-only sessions

3.2 Password Policy

Minimum Length:	12 characters
Complexity:	Must include uppercase, lowercase, number, and special character
Expiration:	Lab credentials rotated every 90 days
Lockout Policy:	5 failed attempts triggers 30-minute lockout (enforced via AD GPO)
Reuse:	Last 5 passwords may not be reused

4. NETWORK SECURITY POLICY

Network Segmentation:	All lab VMs operate on isolated internal network SOC-Lab-Network (192.168.10.0/24)
Firewall:	pfSense CE 2.7.2 enforces perimeter rules — no inbound connections from host
Attacker Isolation:	Kali Linux (192.168.10.30) must NEVER be connected to NAT or bridged adapter
Traffic Monitoring:	All traffic within SOC-Lab-Network is subject to Wazuh SIEM monitoring
Encryption:	Wazuh dashboard accessible only via HTTPS (port 443) — HTTP disabled
Remote Access:	No remote access to lab VMs from outside the host machine

5. INCIDENT RESPONSE POLICY

5.1 Detection & Alerting

The Wazuh SIEM serves as the primary detection and alerting platform. All monitored endpoints must have an active Wazuh agent. Custom detection rules must be documented with trigger logic, expected behavior, and response actions.

5.2 Incident Classification

Severity	Wazuh Level	Examples	Response Time
Critical	12–15	Ransomware, root compromise, data exfiltration	Immediate
High	10–11	Brute-force success, privilege escalation	< 1 hour
Medium	7–9	Repeated failed logins, suspicious process	< 4 hours
Low	4–6	Single failed login, config change	< 24 hours
Informational	1–3	Normal operations, policy compliance	Review weekly

5.3 Incident Response Steps

- 1. Identify:** Detect alert in Wazuh — note rule ID, level, source IP, timestamp
- 2. Contain:** Isolate affected VM if necessary — power off or disconnect network adapter
- 3. Investigate:** Review logs in Wazuh alerts.log and Windows Event Viewer — document Five Ws
- 4. Eradicate:** Remove malicious user, process, or file — revert VM snapshot if needed
- 5. Recover:** Restore normal operations — verify agent still connected and reporting
- 6. Document:** Write incident report with timeline, IOCs, ATT&CK; mapping, and lessons learned

6. CLOUD SECURITY POLICY

CloudTrail:	Enabled on all AWS accounts — logs retained in S3 for 90 days minimum
IAM Policy:	No root account used for day-to-day operations — IAM users only
Least Privilege:	All IAM users provisioned with minimum required permissions
MFA:	Required on all IAM users with console access — enforced
Access Keys:	Never committed to GitHub or shared in public forums — rotate every 90 days
S3 Buckets:	CloudTrail log buckets set to private — no public access
Regions:	Resources deployed in us-east-2 only — no multi-region sprawl

7. DATA CLASSIFICATION & RETENTION

Classification	Examples	Handling	Retention
Public	GitHub README, build guide	May be shared publicly	Indefinite
Internal	Lab screenshots, configs	Lab use only — no public posting	1 year
Confidential	Passwords, access keys	Never shared or committed to git	90 days then rotate
Restricted	PII (none in lab)	Must not be stored in lab	Not applicable

8. POLICY COMPLIANCE & REVIEW

Review Cycle:	This policy is reviewed and updated every 6 months or after a significant incident
Version:	1.0 — Initial release May 2026
Owner:	Lance Vidaure — SOC Lab Administrator
Compliance:	Aligned with NIST SP 800-53, CIS Controls v8, and ISO 27001 principles
Enforcement:	Violations result in immediate suspension of lab access and credential rotation

RISK ASSESSMENT

Home SOC Lab — Security Risk Register & Treatment Plan

Prepared by: Lance Vidaure | Date: May 16, 2026 | Version: 1.0 | Framework: NIST SP 800-30

1. RISK ASSESSMENT METHODOLOGY

This risk assessment follows the NIST SP 800-30 framework. Risks are evaluated based on two dimensions: **Likelihood** (probability of occurrence) and **Impact** (consequence if realized). Risk scores are calculated as Likelihood × Impact on a 1–5 scale, producing a score of 1–25.

	Impact 1 (Negligible)	Impact 2 (Minor)	Impact 3 (Moderate)	Impact 4 (Major)	Impact 5 (Critical)
Likelihood 5 (Almost Certain)	5	10	15	20	25
Likelihood 4 (Likely)	4	8	12	16	20
Likelihood 3 (Possible)	3	6	9	12	15
Likelihood 2 (Unlikely)	2	4	6	8	10
Likelihood 1 (Rare)	1	2	3	4	5

■ High (15–25) ■ Medium (8–12) ■ Low (1–6)

2. RISK REGISTER

R-001: Reconnaissance Not Detected (nmap)		Score: 15 — HIGH	Open
Description:	Attacker performs network service discovery using nmap against monitored hosts. Wazuh generates no alert — detection gap confirmed during Phase 4 simulation.		
Threat:	External attacker or insider performing reconnaissance prior to exploitation		
Vulnerability:	Wazuh relies on host-based agents — no network-layer IDS configured		
L × I:	Likelihood: 5/5 × Impact: 3/5 = Risk Score: 15/25		
Controls:	None — gap identified during simulation		
Treatment:	Deploy Suricata IDS on pfSense or Ubuntu to detect port scans at network layer. Add Wazuh rule for rapid connection attempts from single source.		
Residual Risk:	Medium (8)		

R-002: SSH Brute-Force Attack		Score: 16 — HIGH	Open
Description:	Attacker uses Hydra or Metasploit to attempt password guessing against SSH service on Ubuntu. Multiple failed authentication attempts in short timeframe.		
Threat:	Automated credential stuffing or targeted brute-force attack against SSH		
Vulnerability:	SSH password authentication enabled; no rate limiting or automatic blocking		
L × I:	Likelihood: 4/5 × Impact: 4/5 = Risk Score: 16/25		
Controls:	Wazuh rules 5503/5760 detect failed SSH logins (confirmed in simulation)		
Treatment:	Install Fail2Ban to auto-block IPs after 3 failed attempts. Disable password auth — enforce SSH key-based authentication only. Add custom Wazuh rule to alert on 3+ failures in 60 seconds.		
Residual Risk:	Low (4)		

R-003: Privilege Escalation — New Admin Account		Score: 15 — HIGH	In Progress
Description:	Attacker or unauthorized user creates a new local administrator account on Windows Server, gaining persistent privileged access.		
Threat:	Insider threat or post-exploitation persistence via new privileged account		
Vulnerability:	Default Windows configuration allows Administrator to create local accounts		
L × I:	Likelihood: 3/5 × Impact: 5/5 = Risk Score: 15/25		
Controls:	Wazuh detects Event IDs 4720/4732/4738 — confirmed in simulation. Custom rule 100003 configured.		
Treatment:	Implement GPO restricting local account creation. Configure Wazuh alert to notify immediately on Event ID 4720. Review new accounts weekly.		
Residual Risk:	Low (5)		

R-004: AWS IAM Credential Exposure		Score: 12 — MEDIUM	Remediated
Description:	AWS access keys for soclab-analyst inadvertently exposed in chat, GitHub, or other public forum — allowing unauthorized access to AWS account.		
Threat:	Credential harvesting from public repositories or communication channels		
Vulnerability:	Access keys shared outside secure channels — risk of token theft		
L × I:	Likelihood: 3/5 × Impact: 4/5 = Risk Score: 12/25		
Controls:	MFA enabled on soclab-analyst. ReadOnlyAccess policy limits blast radius.		
Treatment:	Rotate exposed access keys immediately. Enable AWS CloudTrail alerts for unusual API activity. Store credentials in password manager only. Never commit to GitHub.		
Residual Risk:	Low (4)		

R-005: Wazuh Service Unavailability		Score: 12 — MEDIUM	Mitigated
Description:	Wazuh indexer, manager, or dashboard fails to start due to timeout or resource exhaustion — leaving endpoints unmonitored.		
Threat:	Resource exhaustion on 8GB host machine causing SIEM downtime		
Vulnerability:	Wazuh requires significant RAM — startup timeouts observed repeatedly in lab		
L × I:	Likelihood: 4/5 × Impact: 3/5 = Risk Score: 12/25		
Controls:	TimeoutStartSec=180 override configured for indexer and manager services		
Treatment:	Add startup health check script. Configure Wazuh to send alert if agent disconnects for >5 minutes. Document startup sequence and boot order.		
Residual Risk:	Low (6)		

R-006: Kali Linux Connected to External Network		Score: 10 — MEDIUM	Mitigated
Description:	Attacker VM accidentally configured with NAT adapter — attack tools could reach external systems, violating lab isolation policy.		
Threat:	Accidental or intentional use of lab attack tools against external targets		
Vulnerability:	VirtualBox network adapter misconfiguration during VM setup		
L × I:	Likelihood: 2/5 × Impact: 5/5 = Risk Score: 10/25		
Controls:	Kali configured with Internal Network adapter only — verified during Phase 4 setup		
Treatment:	Add VirtualBox startup checklist verifying Kali adapter. Document in README. Never add NAT adapter to Kali VM.		
Residual Risk:	Low (2)		

R-007: Weak Password on Lab Accounts		Score: 8 — MEDIUM	In Progress
Description:	Lab accounts use weak or default passwords, making them susceptible to brute-force or credential guessing attacks.		
Threat:	Automated brute-force or credential guessing against lab accounts		
Vulnerability:	No centralized password management — manual password setting for each VM		
L × I:	Likelihood: 2/5 × Impact: 4/5 = Risk Score: 8/25		
Controls:	AD GPO enforces password complexity and lockout policy on domain accounts		
Treatment:	Use a password manager for all lab credentials. Enforce 12+ character passwords across all VMs. Enable Wazuh monitoring on all authentication events.		
Residual Risk:	Low (4)		

R-008: SSH Fingerprint Disclosure		Score: 8 — MEDIUM	Open
Description:	Metasploit ssh_version module successfully fingerprinted Ubuntu SSH version and encryption algorithms — no Wazuh alert generated.		
Threat:	Attacker enumerates SSH service details to identify exploitable vulnerabilities		
Vulnerability:	SSH version banner disclosure — no detection rule for service fingerprinting		
L × I:	Likelihood: 4/5 × Impact: 2/5 = Risk Score: 8/25		
Controls:	None — detection gap confirmed in Phase 4 simulation		
Treatment:	Configure SSH to suppress version banner in sshd_config. Add Wazuh rule to alert on rapid SSH connection attempts without authentication attempt.		
Residual Risk:	Low (4)		

3. RISK SUMMARY

Risk ID	Title	Score	Level	Status
R-001	Reconnaissance Not Detected	15	HIGH	Open
R-002	SSH Brute-Force Attack	16	HIGH	Open
R-003	Privilege Escalation — New Admin	15	HIGH	In Progress
R-004	AWS IAM Credential Exposure	12	MEDIUM	Remediated
R-005	Wazuh Service Unavailability	12	MEDIUM	Mitigated
R-006	Kali Connected to External Network	10	MEDIUM	Mitigated
R-007	Weak Password on Lab Accounts	8	MEDIUM	In Progress
R-008	SSH Fingerprint Disclosure	8	MEDIUM	Open

4. COMPLIANCE FRAMEWORK ALIGNMENT

The SOC lab security controls and policies are aligned with the following industry frameworks:

NIST SP 800-53	AC-2 Account Management, AC-6 Least Privilege, AU-2 Audit Events, IR-4 Incident Handling, SC-7 Boundary Protection
CIS Controls v8	Control 1 (Inventory), Control 4 (Secure Config), Control 6 (Access Control), Control 8 (Audit Logs), Control 13 (Network Monitoring)
ISO 27001	A.9 Access Control, A.12 Operations Security, A.13 Communications Security, A.16 Incident Management
MITRE ATT&CK;	Detection coverage mapped to T1046, T1110, T1136, T1592, T1078 — documented in Phase 4 incident report